INSTITUTO TECNOLÓGICO DE COSTA RICA
ESCUELA DE INGENIERÍA EN COMPUTADORES
CE-1115 Seguridad de la Información

Proyecto · Parte 1 · Diseño del control de acceso

Documento de control de acceso

Modelo de acceso, controles de historial y separación de responsabilidades

Entregable 2 de 5

Cliente

Verdeazul Carbono S.A.
Certificación de captura de carbono · Pérez Zeledón, Costa Rica

Grupo 6

Integrante	**Carné**
Randall Bryan Bolaños López	2019043784
Javier Tenorio Cervantes	2020065308
Julio Varela Venegas	2019008041
Axel Flores Lara	2021453573

Prof. MSc. Andrés Vargas Rivera
Semestre II, 2026

Fecha de entrega: 15 de octubre de 2026

Índice

1. Las decisiones, en una página **1**

2. Lo que el caso exige y dónde se resuelve **1**

3. Modelo de control de acceso **3**

3.1. Qué característica del negocio lo hace apropiado . . . 3

3.2. Por qué no los otros tres . . . 4

3.3. Dónde está la frontera del híbrido . . . 4

3.4. Qué nivel de RBAC . . . 5

3.5. Riesgo de explosión de roles . . . 5

4. Controles basados en historial **6**

4.1. Cómo se distingue lo legítimo de la amenaza . . . 6

4.2. Los cuatro controles . . . 7

4.3. Arranque, calibración y límites . . . 8

5. Separación de responsabilidades **9**

5.1. La acción que nadie debe completar solo . . . 9

5.2. La técnica elegida . . . 9

5.3. La enmienda: quién solicita, quién revisa y quién autoriza . . . 10

5.4. Alternativas descartadas . . . 11

5.5. Cómo se refleja en la matriz . . . 11

5.6. Qué fricción introduce y cómo se maneja . . . 12

Anexo A. Respuestas del cliente y supuestos declarados **13**

Referencias **14**

1 Las decisiones, en una página

Este documento decide tres cosas para la plataforma de Verdeazul: qué modelo de control de acceso la gobierna, qué controles miran el historial de cada usuario y con qué técnica se impide que una sola persona complete la acción más delicada del negocio. Cada decisión termina convertida en una celda o en una regla de la matriz (Entregable 3), donde se puede comprobar.

Decisión	Lo que se eligió	Sección
Modelo de control de acceso	Roles con restricciones ($RBAC_2$) como base. Un conjunto cerrado de condiciones de atributo acota cada permiso a la finca, el estado y el momento correctos. Las condiciones solo restringen.	3
Modelos descartados	DAC, MAC y ABAC puro, cada uno por una razón del caso.	3.2
Nivel de RBAC	$RBAC_2$: siete roles planos con restricciones. Sin jerarquía.	3.4
Controles de historial	Cuatro, uno de cada tipo: frecuencia (H1), tiempo (H2), combinado (H3) y secuencia (H4). Los tres primeros responden por niveles: aviso, verificación adicional y restricción temporal.	4
Acción crítica	Emitir un certificado de carbono. En segundo lugar, corregir una medición ya congelada.	5.1
Técnica de separación	Separación por etapas del flujo, comprobada medición por medición con el historial de autoría, y reforzada con roles mutuamente excluyentes.	5.2
Enmiendas	Solicitar, corregir, revisar y autorizar: cuatro pasos y al menos tres personas. Revisa un verificador distinto del original cuando la enmienda es material.	5.3

El documento se revisó después de la consulta al cliente. Las marcas como **[minuta P-07]** señalan decisiones que salen de una de sus respuestas, recogidas en la minuta (Anexo A del informe de políticas). Las marcas como [supuesto P-13] señalan supuestos que el equipo fijó y documentó porque el cliente no dio el dato. El Anexo A de este documento resume unas y otros.

2 Lo que el caso exige y dónde se resuelve

El diseño sale de la carta de encargo y de lo que el cliente precisó al responder las consultas. Cada frase se convierte en un requisito, con su consecuencia de diseño y con la regla y el caso de prueba de la matriz (Entregable 3) donde se comprueba.

Id.	Lo que dice el cliente	Consecuencia para el diseño	Se comprueba en
En la carta de encargo			
R1	«*Si alguien cambió un dato, quién fue y cuándo.*»	Nada se sobrescribe: todo cambio es una versión nueva con autor.	C2, C9; T-03, T-04
R2	«*Si un certificado se emitió, quién lo aprobó.*»	Aprobar es un acto personal, ligado para siempre al certificado.	C3, C4; T-05
R3	«*Si alguien anduvo viendo información que no le correspondía, aunque tuviera permiso de verla.*»	El permiso no basta: hay que vigilar cómo se usa.	C1, H1, H3; T-02, T-18, T-19
R4	«*Cuando cierra ya nadie debería poder cambiar nada.*»	El permiso depende del estado del período.	C2, C14; T-04, T-21

Id.	Lo que dice el cliente	Consecuencia para el diseño	Se comprueba en
R5	«*Que quede como una enmienda registrada, no como una edición silenciosa.*»	Corregir es un flujo aparte, con sus propios permisos.	C7 a C10; T-11 a T-14
R6	«*Nos preocupa además que la misma persona pueda medir y aprobar.*»	Separación de responsabilidades.	C3, H4; T-06
R7	Auditores: «*ver absolutamente todo y no deberían poder tocar nada.*»	Un rol de solo lectura, acotado en el tiempo.	Fila AUD, C6, C18; T-09, T-10, T-31
R8	Dueños: «*solo deberían ver lo suyo [. . .] son competencia entre ellos.*»	El permiso depende de la relación del sujeto con la finca.	C5; T-08
R9	«*Un certificado que se emitió dos veces sobre la misma hectárea.*»	La emisión depende de lo ya emitido.	C4, C11; T-07, T-15
R10	«*Poder explicarle a un auditor por qué el sistema está diseñado así.*»	El modelo debe poder enumerarse y leerse.	La matriz completa
En las respuestas a la consulta			
R11	«*garantizar una revisión independiente, sin impedir que el personal pueda asumir otras responsabilidades*» **[minuta P-01]**	La separación se comprueba por medición; un verificador mide con una habilitación temporal.	C3, C12; T-26
R12	«*distinguir entre registrar, modificar, revisar y aprobar información*» **[minuta P-06]**	El cierre detiene las dos primeras; las otras dos siguen sobre lo enviado a tiempo.	C3, C14; T-17, T-21, T-22
R13	«*independencia entre quienes solicitan, revisan y autorizan modificaciones importantes*» **[minuta P-07]**	En una enmienda, cada paso lo da una persona distinta.	C8, C10; T-23, T-24
R14	«*ni que existan dos certificados vigentes respaldando la misma captura de carbono*» **[minuta P-08]**	Revocar y reemitir es un solo acto del sistema.	C4; T-25
R15	«*que las respuestas sean diferentes según la gravedad del comportamiento*» **[minuta P-10]**	Los controles de historial responden por niveles, y no bloquean de entrada.	H1, H3; T-18, T-19, T-33
R16	«*cierta flexibilidad operativa, pero no [. . .] acceso permanente a la información de todas las fincas*» **[minuta P-11]**	Asignaciones temporales, que vencen solas.	C1, C19; T-27
R17	«*evitar que una persona utilice sus responsabilidades dentro de la empresa para beneficiar indebidamente una propiedad con la que tenga alguna relación*» **[minuta P-15]**	Declaración de vínculos y abstención.	C13, C17; T-29
R18	«*que el diseño no dependa de cantidades fijas de usuarios, fincas o asignaciones*» **[minuta P-02]**	Ni los roles ni los umbrales crecen con el catálogo.	Secciones 3.4 y 4.1

Casi ninguno se decide mirando solo el puesto de la persona: dependen del estado de un período, de la relación con una finca o de lo que el sujeto hizo antes. Y R10 pide que el resultado siga siendo fácil de leer. Esa tensión la resuelve la sección siguiente.

3 Modelo de control de acceso

> **Decisión.** Verdeazul usará **control de acceso basado en roles con restricciones ($\mathbf{RBAC_2}$)**. Sobre esa base, un conjunto pequeño y cerrado de **condiciones de atributo** decide si el permiso del rol aplica a *esta* finca, en *este* estado y en *este* momento. Las condiciones solo pueden restringir: nunca conceden algo que el rol no tenga. Es el enfoque que Kuhn *et al.* (2010) llaman centrado en roles.

3.1 Qué característica del negocio lo hace apropiado

El cliente ya piensa en roles. La carta no describe personas, describe funciones: «*gente que sale a campo*», «*otra gente revisa ese trabajo desde la oficina*», «*quien administra el catálogo de fincas y da de alta a la gente nueva*», «*los auditores externos*» y «*los dueños de las fincas*», más la gerencia que firma. La consulta agregó una: los supervisores del personal de campo, que coordinan las asignaciones de fincas. **[minuta P-05]** El modelo toma las siete tal cual.

La gente rota, las funciones no. El administrador «*da de alta a la gente nueva cuando entra a la empresa*», el año pasado un técnico renunció y se fue a la competencia, y la empresa espera incorporar personal y fincas. **[minuta P-02]** Con roles, un ingreso o una salida es una sola asignación; los permisos quedan amarrados a lo que cambia poco, que es el puesto, y no a lo que rota, que es la persona (Sandhu *et al.*, 1996).

Hay que poder explicarlo. La pregunta de un auditor, «¿qué puede hacer un verificador?», se responde leyendo una fila, y que la misma persona no mida y apruebe es una restricción de RBAC_2.

Rol	Función	Qué decide o hace en el sistema
TEC	Técnico de campo	Registra las mediciones de las fincas que tiene asignadas.
VER	Verificador	Aprueba o devuelve mediciones que no registró; revisa las enmiendas.
SUP	Supervisor de campo	Asigna y reasigna fincas a los técnicos; atiende sus alertas. **[minuta P-05]**
GER	Gerencia de Certificación	Responsable del dato; incluye a la coordinación de certificación. Abre y cierra períodos, autoriza enmiendas y da la segunda firma de altas y roles. **[minuta P-05, P-07]**
ADM	Administrador de catálogo y cuentas	Mantiene el catálogo y las cuentas y registra los períodos; propone, no aprueba.
AUD	Auditor externo	Lee todo y exporta evidencia, dentro de su ventana. **[minuta P-18]**
DUE	Dueño de finca	Lee lo de sus fincas, como titular o como representante. **[minuta P-15]**

3.2 Por qué no los otros tres

Modelo	Razón del descarte, en el caso de Verdeazul	Qué se conserva de él
DAC	En DAC decide el dueño del recurso. Aquí el técnico que crea una medición sería su dueño y podría seguir modificándola o compartirla a su criterio: es exactamente el primer susto de la carta, la medición que alguien cambió después de aprobada. Las hojas de cálculo compartidas de hoy *son* DAC, y bajo ese modelo ocurrieron los dos incidentes. Además, entre dueños que compiten, un permiso compartido por descuido es una fuga que nadie ve.	La idea de titularidad, pero convertida en un atributo que da lectura (regla C5), no en el poder de repartir permisos.
MAC	MAC ordena la información por niveles de secreto. Verdeazul no tiene niveles: todas las fincas son igual de sensibles y lo que hay que separar es una finca de otra, lo que obligaría a crear un compartimento por finca. Y el riesgo principal es de integridad, no de secreto. La variante de MAC para integridad (Biba, 1977) le pone al dato una etiqueta fija, pero la confianza en una medición cambia con su estado y depende de quién hizo el paso anterior. Es el argumento de Clark y Wilson (1987): la integridad comercial se logra con transacciones bien formadas y separación de responsabilidades, no con etiquetas.	Que el usuario no pueda alterar la política: los permisos los fija una autoridad central. MAC sí se usa en la plataforma, para confinar los contenedores (Entregable 4).
ABAC puro	Podría expresarlo todo, pero dejaría de existir la fila que responde «¿qué puede hacer un verificador?»: habría que evaluar todas las reglas contra todas las combinaciones de atributos. Es la dificultad de revisión que señalan Hu *et al.* (2014), y choca con R10 y con la propia exigencia de una matriz. Tampoco hay quien gobierne un catálogo amplio de atributos y reglas en una empresa que viene de hojas de cálculo y no tiene personal especializado. **[minuta P-23]**	Las condiciones de atributo, limitadas a una lista cerrada y solo para restringir.

3.3 Dónde está la frontera del híbrido

Cada petición pasa por tres capas, siempre en el mismo orden, y cada capa responde una pregunta distinta.

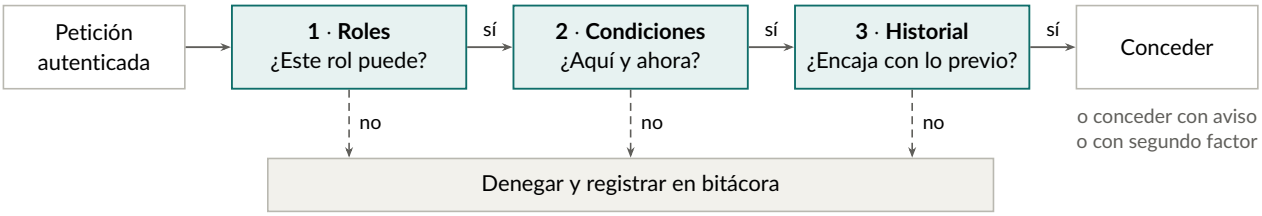


Figura 1: Las tres capas de la decisión. Solo la primera concede; las otras dos solo pueden quitar.

Capa	Qué mira	Ejemplo: aprobar una medición
1 · Roles (RBAC)	Rol del sujeto, verbo y tipo de objeto.	El rol VER tiene *aprobar* sobre mediciones.
2 · Condiciones (atributos)	Asignación, titularidad, vínculo declarado, estado del período, de la medición y de la enmienda, vigencia.	Solo si la medición está ENVIADA y quien aprueba no declaró un vínculo con el titular de la finca.
3 · Historial (HBAC)	Lo que el sujeto hizo antes: autoría, volumen, horario.	Solo si quien aprueba no registró ninguna versión de esa medición.

Cómo se combinan sin contradecirse. El sistema niega por omisión. Una petición se concede solo si la capa 1 la concede *y* ninguna de las otras dos objeta; una negativa en cualquier capa gana. Como la tabla de roles es la única fuente de permisos y las capas 2 y 3 funcionan como filtros, no puede darse el caso de que una regla conceda lo que otra niega. De ahí sale una propiedad útil ante un auditor: la matriz muestra lo *máximo* que cada rol puede llegar a hacer, y cualquier condición solo lo reduce.

La lista de atributos es cerrada. Son de cuatro clases y ninguna más: la relación del sujeto con el objeto (asignación, titularidad, vínculo declarado); el estado del objeto (período, medición, enmienda, certificado, propuesta); el tiempo (vigencia de una cuenta, de una asignación o de un plazo); y la participación previa del sujeto en ese objeto. Agregar una clase nueva es un cambio de diseño que aprueba la Gerencia, no una configuración. Así se evita que el modelo se deslice, regla por regla, hacia el ABAC puro que se descartó.

3.4 Qué nivel de RBAC

Se elige **RBAC_2: roles planos con restricciones**. Ni RBAC_1 ni RBAC_3, porque ambos suponen una jerarquía de roles que aquí no conviene.

Por qué sin jerarquía. Primero, entre las siete funciones no hay una cadena de mando en la que un rol sea «el otro más algo». La única herencia tentadora, que el verificador herede del técnico porque «también sabe medir», le daría al verificador el permiso de registrar siempre, y rompería la separación que el cliente pide; Sandhu *et al.* (1996) advierten justamente que jerarquías y restricciones interfieren entre sí. Segundo, la herencia vuelve implícitos los permisos, y la matriz debe poder leerse sin nada implícito: con roles planos, una fila es toda la verdad sobre un rol. Tercero, con siete roles la jerarquía no ahorra nada.

Qué restricciones se usan.

- **Exclusión estática.** Cada persona tiene un solo rol; los pares de roles no se reúnen en la misma persona. Hay una excepción, que es la siguiente.
- **Exclusión dinámica entre TEC y VER.** El cliente confirmó que algunos verificadores fueron técnicos y que, en situaciones excepcionales, pueden medir. **[minuta P-01]** Un verificador puede recibir una habilitación temporal de técnico, con fecha de fin, aprobada por la Gerencia; no activa los dos roles en la misma sesión.
- **Identidad única.** Una persona, una cuenta. Las restricciones no sirven de nada si alguien tiene dos identidades, y los propios autores del modelo lo advierten.
- **Cardinalidad.** Al menos dos verificadores activos mientras haya mediciones sin dictamen. Es el mínimo que exige una revisión independiente, no un supuesto de tamaño: ninguna otra regla depende de cuántas personas o fincas haya. **[minuta P-02]**
- **Prerrequisito.** Una cuenta de auditor no se activa sin una ventana de vigencia, ni una habilitación temporal sin su fecha de fin.

Quién administra los roles. ADM es el rol administrativo y está separado de los roles operativos: da de alta cuentas y *propone* roles, pero la asignación solo surte efecto cuando GER la aprueba, y nadie interviene en su propia cuenta (regla C12 de la matriz). [supuesto P-20]

3.5 Riesgo de explosión de roles

El riesgo existe y está en un punto preciso: aparece cuando se usa un rol para decir *dónde* o *cuándo* aplica un permiso. Si el aislamiento entre dueños se resolviera con roles haría falta un rol por finca, y si el alcance de un técnico se resolviera igual aparecerían roles como «Técnico Zona Sur 2027». El número de roles crecería con el catálogo, que es justo lo que el cliente pidió evitar. **[minuta P-02]**

Se evita con una regla: **el alcance nunca es un rol, es un atributo**. La finca asignada, la titularidad y el estado

del período viven en las condiciones de la capa 2. Solo se crea un rol cuando aparece una función de trabajo nueva, y esa creación pasa por la Gerencia.

La consulta puso a prueba la regla. Trajo cinco necesidades nuevas: el verificador que mide por excepción, el técnico que apoya a un compañero, la sociedad con un representante, el empleado con un vínculo con un dueño y el supervisor que asigna las fincas. Solo la última es una función de trabajo y solo ella produjo un rol; las otras cuatro son atributos. Los roles son siete, y lo seguirán siendo con el doble de fincas, de dueños o de personal.

4 Controles basados en historial

> **Decisión.** Sí se implementan controles de historial: **cuatro, uno de cada tipo**. Se evalúan después de los roles y las condiciones, con reglas explícitas del tipo «si… entonces», no con aprendizaje automático: una regla se le puede leer a un auditor y se puede probar, y el personal de Verdeazul, aunque crezca, no produce datos suficientes para entrenar un modelo confiable.

Por qué hacen falta. El técnico del último párrafo de la carta «*tenía el permiso para verlas*». Es el caso que se estudió en clase con Chelsea Manning: el modelo de roles no vio nada raro porque el rol tenía el permiso (Vargas Rivera, 2026b). La primera respuesta del diseño es estructural: ese permiso deja de existir, porque un técnico solo ve las fincas que tiene asignadas (regla C1). El cliente lo confirmó, con una condición: flexibilidad para apoyar a un compañero, sustituir a un ausente o atender una visita extraordinaria. **[minuta P-11]** Eso se resuelve con asignaciones temporales que crea el supervisor y vencen solas (C19), no con un permiso permanente. Pero el verificador, el supervisor, la gerencia, el administrador y el auditor sí necesitan leer muchas fincas por su función. Para ellos el permiso es legítimo y solo el historial distingue el uso normal del anormal.

Se valoró también la política de Muralla China (Brewer y Nash, 1989), el control de historial clásico para conflictos de interés: quien consulta los datos de un cliente pierde el acceso a los de su competidor. No sirve aquí. Todos los dueños compiten entre sí, de modo que cada empleado quedaría limitado a una sola finca.

4.1 Cómo se distingue lo legítimo de la amenaza

El cliente pidió, como mínimo, detectar y avisar; no bloquear de inmediato, porque una actividad extraordinaria puede ser legítima; y responder distinto según la gravedad. **[minuta P-10]** El criterio del diseño es contar **señales**, no fijarse en una sola:

- **Volumen:** cuántas fincas distintas consulta, frente a lo habitual en su rol.
- **Novedad:** si son fincas que nunca consultó y que no están en su cola ni en sus asignaciones.
- **Momento:** si ocurre fuera de la jornada de su rol.
- **Insistencia:** si continúa después de un aviso o de varias denegaciones.

El trabajo legítimo extraordinario suele mostrar una señal: mucho volumen en la última semana de un período, o un sábado de puesta al día. La extracción de la cartera las muestra juntas, y fue exactamente así el año pasado: un fin de semana, cientos de fincas, ninguna propia. Por eso ninguna señal aislada restringe, y la respuesta sube con el número de señales.

Nivel	Qué hace el sistema	Quién se entera
1 · Aviso	Concede y genera una alerta. El usuario no nota nada.	El supervisor, si es personal de campo; GER para los demás.
2 · Verificación adicional	Concede si el usuario confirma con su segundo factor y escribe un motivo.	Los mismos. El motivo queda en la alerta.
3 · Restricción temporal	No abre fincas *nuevas* hasta el siguiente día hábil. La cuenta sigue activa y el trabajo en curso continúa.	GER, de inmediato. La levanta el supervisor o GER, en un paso registrado.

4.2 Los cuatro controles

H1 · Consulta masiva de fincas	Tipo: frecuencia
Regla	Cuenta las fincas distintas cuyo detalle consultó el sujeto en las últimas 24 horas y las compara con tres umbrales de su rol: sobre el primero, nivel 1; sobre el segundo, nivel 2; sobre el tercero, nivel 3. Los intentos denegados por alcance cuentan doble y escalan por sí solos: aviso a la tercera denegación en diez minutos, verificación a la quinta y 30 minutos de restricción a la décima.
Riesgo que mitiga	AM-04, el empleado con credenciales válidas que se lleva la cartera de fincas. También AM-07 y AM-08: un dueño o una cuenta robada que prueban identificadores ajenos.
Datos y plazo	Por cada lectura: sujeto, rol, finca, tipo de objeto, hora, origen y decisión. La regla necesita 90 días en línea; la conservación total sigue la política de bitácora. [supuesto P-19]
Decisión del motor	Las tres: conceder, conceder con restricciones, denegar las fincas nuevas.
Falsos positivos	El verificador con la cola acumulada en la última semana del período; la gerencia preparando la auditoría. En los niveles 1 y 2 el usuario sigue trabajando. En el 3 ve qué regla se activó y a quién acudir. El auditor no se restringe: sus consultas y exportaciones se resumen a GER.
Valores	Son parámetros por rol, no constantes: se calibran con las consultas reales (aviso cerca del percentil 95 del rol, verificación cerca del 99 y restricción en el doble de este) y crecen con el catálogo sin tocar la regla. **[minuta P-02]** Hasta tener datos: 40, 60 y 80 fincas por día. [supuesto P-13]

H2 · Decisiones fuera de jornada	Tipo: tiempo
Regla	Una acción de decisión (aprobar, devolver, revisar, autorizar, abrir o cerrar un período, aprobar un alta o un rol) pedida fuera de la jornada del rol se concede solo con segundo factor y motivo, y aparece en el resumen diario de GER. El registro de mediciones no se restringe: los técnicos vuelven tarde del campo y registran cuando hay conexión. **[minuta P-22]**
Riesgo que mitiga	AM-08, la cuenta robada que se usa de madrugada. AM-02 y AM-03, la decisión irregular que se toma cuando nadie mira.
Datos y plazo	La jornada de cada rol, como configuración aprobada por GER, y la hora del servidor. No necesita historial previo: funciona desde el primer día.
Decisión del motor	Conceder con restricciones (nivel 2).
Falsos positivos	Trabajo hasta tarde en el cierre de un período; un sábado de puesta al día. Cuesta diez segundos y una línea de texto; no detiene a nadie.
Valores	Lunes a viernes, de 6:00 a 19:00, para VER, SUP, GER y ADM. [supuesto P-12]

H3 · Lectura masiva fuera de jornada	Tipo: combinada
Regla	Si coinciden tres señales (fuera de jornada; más fincas distintas en 60 minutos que el umbral, inicialmente 10; y más de la mitad nunca consultadas por el sujeto en 90 días), pide segundo factor y motivo y avisa de inmediato a GER. Si después de confirmar la pauta sigue con otras tantas fincas nuevas, aplica el nivel 3.
Riesgo que mitiga	AM-04. Es la firma exacta del incidente de la carta.
Datos y plazo	Los de H1, más el conjunto de fincas que cada sujeto consultó en los últimos 90 días.
Decisión del motor	Conceder con restricciones y, si hay insistencia, denegar las fincas nuevas.
Falsos positivos	Pocos por diseño, porque exige que coincidan tres señales. El previsible es un verificador recién contratado, sin historial, que trabaja un sábado de cierre: confirma una vez y sigue. Durante los primeros 30 días de una cuenta la tercera señal se da por cumplida.

H4 · Quien participó antes no decide después	Tipo: secuencia
Regla	No aprueba una medición quien registró o modificó cualquiera de sus versiones. No revisa una enmienda quien la solicitó ni quien figura como autor de la medición. No la autoriza quien la solicitó o la revisó. Son las reglas C3, C10 y C8 de la matriz.
Riesgo que mitiga	AM-02: que la misma persona mida y apruebe, incluso con años de diferencia y después de cambiar de puesto.
Datos y plazo	El autor de cada versión de cada medición y de cada paso de cada enmienda. Diez años, porque es parte de la trazabilidad del certificado.
Decisión del motor	Denegar. Ningún segundo factor la levanta.
Falsos positivos	Ninguno en sentido estricto: la regla es determinista. El costo es operativo y se trata en la sección 5.6.

4.3 Arranque, calibración y límites

Arranque en frío. H2 y H4 no dependen de ninguna línea base. Para H1 y H3, el primer período corre en modo de observación: las reglas registran y avisan, pero no piden confirmación ni restringen. Con esos datos se fijan los umbrales de cada rol, que se revisan al cierre de cada período. Son configuración que aprueba GER, y cada cambio queda en bitácora.

La rana hervida. Los umbrales son por rol, no por la costumbre de cada persona. Quien suba su actividad poco a poco para volverla «normal» sigue topando con el mismo techo.

Lo que no ve. Quien copie a mano tres fincas por día, por debajo de todos los umbrales, pasa inadvertido. Los controles de historial vuelven la extracción lenta y visible, no imposible. Es un riesgo residual que se declara en el Entregable 4.

Proporcionalidad. El personal sabe, desde que firma la política de uso aceptable, que sus consultas quedan registradas y se analizan. Solo se miden accesos a objetos del negocio. [supuesto P-14]

> **El técnico del último párrafo, hoy.** La carta dice «*nos gustaría que el sistema al menos se diera cuenta*». Así se vería el mismo fin de semana:
>
> 1. Abre una finca que no tiene asignada. Se deniega (C1) y cuenta doble para H1.
> 2. A la tercera denegación su supervisor recibe un aviso; a la quinta, el sistema le pide el segundo factor

y un motivo; a la décima, lo detiene media hora.
3. Si de verdad necesitaba esa finca, el supervisor le da una asignación temporal y sigue.
4. Si fuera un verificador, que sí lee cualquier finca, H3 le pide confirmación en la undécima, avisa a GER en ese momento y restringe las fincas nuevas en la vigésima primera.
5. Al presentar la renuncia, la política de baja genera un reporte de sus consultas de 90 días.

El diseño original suspendía la sesión en el segundo paso; se cambió por lo que pidió el cliente: avisar primero y restringir solo si hay insistencia. **[minuta P-10]**

5 Separación de responsabilidades

5.1 La acción que nadie debe completar solo

Es la **emisión de un certificado de carbono**, que resulta de dos pasos: registrar la medición y aprobarla. Si una sola persona pudiera dar los dos, podría inflar la biomasa de una finca, aprobar su propio dato y dejar que el sistema emitiera un certificado por toneladas que no existen. Ese certificado se vende en un mercado internacional por dinero real y, como dice la carta, «*respalda una tonelada de carbono que alguien, en algún lugar, está dejando de compensar por otra vía*». El día que un auditor lo rastree, el daño no se limita a ese certificado: pone en duda todos los demás.

La segunda acción crítica es **corregir una medición ya congelada**, sea porque está aprobada o porque su período cerró. Es el primer susto de la carta, y se trata con la misma técnica.

5.2 La técnica elegida

Decisión. Separación por etapas del flujo: quien inicia el proceso no puede cerrarlo. Se comprueba *medición por medición*, con el historial de autoría, y no solo por el puesto que la persona ocupa hoy. Se refuerza con roles mutuamente excluyentes.

El sistema no pregunta «¿qué rol tiene?» sino «¿participó en *esta* medición?». En la literatura es la separación basada en el objeto o en el historial (Nash y Poland, 1990; Simon y Zurko, 1997).

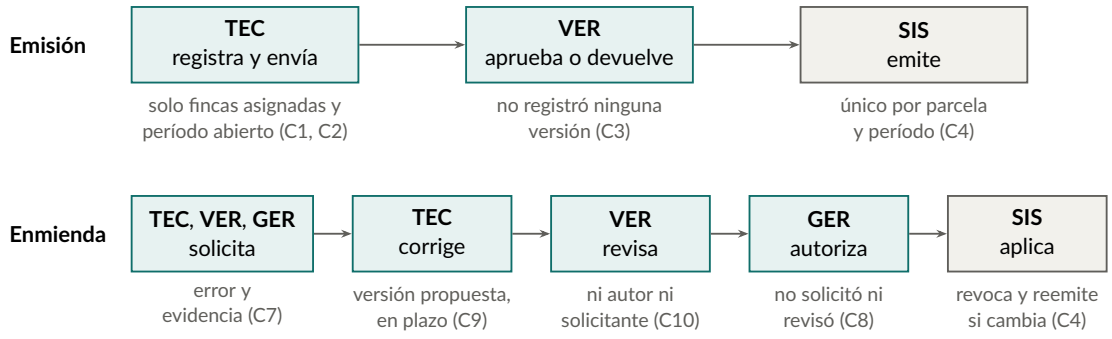


Figura 2: Los dos flujos críticos. En ninguno la persona que inicia es la que cierra, y la emisión no la ejecuta ninguna persona.

Por qué es la adecuada para este riesgo.

1. **Apunta al riesgo tal como lo dijo el cliente**: que la misma persona mida y apruebe. No que tenga dos puestos, sino que haga las dos cosas sobre el mismo dato.

2. **Da las dos cosas que el cliente pidió a la vez**: revisión independiente y personal que puede asumir otras tareas. **[minuta P-01]** Una separación por puesto obligaría a escoger. Con esta, un verificador que mide por excepción simplemente no podrá aprobar lo que midió.
3. **Sobrevive a los cambios de puesto.** Un técnico ascendido a verificador conserva su historial: no podrá aprobar lo que midió el año anterior. Es la lección del caso Kerviel visto en clase, donde el problema fue lo que la persona arrastró de su puesto anterior (Vargas Rivera, 2026a).
4. **No depende de que los roles estén bien administrados.** Si un día se asigna mal un rol, la regla sigue protegiendo cada medición.
5. **Deja evidencia por certificado.** Cada certificado muestra dos nombres distintos, que es lo que el auditor va a pedir. Coincide con el principio de imparcialidad de ISO/IEC 17029:2019, citada solo como referencia: el cliente no audita bajo una norma determinada. **[minuta P-18]**

5.3 La enmienda: quién solicita, quién revisa y quién autoriza

El cliente fijó tres cosas. **[minuta P-07]** La pueden solicitar el técnico responsable, un verificador o el personal de certificación. La autorización final es de la Gerencia y debe apoyarse en una revisión técnica. Y quienes solicitan, revisan y autorizan deben ser independientes. Dejó una al criterio del equipo: si el revisor debe ser siempre un verificador distinto del que aprobó la medición original.

¿Quién revisa?	A favor	En contra
Siempre un verificador distinto del original	Nadie dictamina sobre su propio error.	Una corrección de forma queda esperando a una persona que quizá no está.
Puede ser el original	Conoce la medición; es lo más rápido.	Quien aprobó el dato erróneo tiene interés en que el error parezca menor.
Según lo que cambia (elegida)	Exige al distinto donde hay algo que ganar o que esconder.	Hay que clasificar la enmienda. Lo hace el sistema, no una persona.

Restricciones que el equipo considera necesarias.

1. **Quien revisa nunca es autor de la medición ni quien solicitó la enmienda** (C10).
2. **Quien autoriza no la solicitó, no la revisó ni participó en la medición** (C8). Si la solicita alguien de la Gerencia, la autoriza otra persona de la Gerencia.
3. **Si la enmienda es material, quien revisa tampoco es el verificador original.** Es material cuando cambia un dato que entra en el cálculo de las toneladas o cuando la medición ya tiene un certificado emitido. El sistema lo determina comparando las dos versiones, de modo que nadie puede declarar «menor» una enmienda para escoger al revisor.
4. **El verificador no corrige.** La versión corregida la registra el técnico, como versión propuesta, y no rige hasta la autorización final. **[minuta P-03]**
5. **El destino del certificado lo decide una regla, no una persona.** La revisión técnica evalúa el efecto sobre el certificado. Si las toneladas certificadas cambian, al autorizar el sistema lo revoca y emite el reemplazo en un solo acto; si no cambian, sigue vigente con la enmienda anotada. Nunca hay dos vigentes y ninguno se borra. Si ya fue comercializado, la Gerencia lo deja registrado y coordina con las partes. **[minuta P-08]**

5.4 Alternativas descartadas

Técnica	Cómo se aplicaría aquí	Por qué no es la técnica principal
Roles mutuamente excluyentes, estáticos ($RBAC_2$)	Nadie tiene a la vez TEC y VER.	Comprueba el puesto de hoy, no quién tocó esta medición: no cubre al técnico que asciende. Li *et al.* (2007) muestran que la exclusión de roles es un mecanismo para aproximar la separación, no la separación misma. Además impediría que un verificador mida por excepción, que el cliente quiere conservar. **[minuta P-01] Se conserva como refuerzo** en los demás pares de roles.
Roles excluyentes, dinámicos	No activar TEC y VER en la misma sesión.	Basta cerrar la sesión y abrir otra para medir primero y aprobar después. Sola, demora el fraude y no lo impide. **Se usa como refuerzo** para la pareja TEC–VER, detrás de la regla C3.
Doble control (cuatro ojos)	Dos verificadores confirman cada aprobación.	Duplica el trabajo de verificación en cada certificado, con cualquier tamaño de equipo, para cubrir un riesgo que la segunda persona del flujo ya cubre. Costo: el más alto de todas las opciones.
Segregación temporal (acceso justo a tiempo)	El permiso de aprobar se concede por una ventana.	Limita *cuándo*, no *quién*: alguien con los dos permisos en ventanas distintas sigue pudiendo medir y aprobar. **Sí se usa** donde el problema es la duración del privilegio: la asignación temporal (C19), la habilitación de un verificador para medir (C12), el plazo de la enmienda (C9) y la cuenta del auditor (C6).
Rotación de responsabilidades	Cambiar cada período qué técnico mide cada finca y qué verificador lo revisa.	No impide un acto individual; dificulta el fraude sostenido. Cuesta conocimiento de la finca y depende de cuántas personas haya, un dato que el cliente pidió no fijar. **[minuta P-02]** Se recomienda como complemento contra la colusión; el supervisor la aplica al asignar.

5.5 Cómo se refleja en la matriz

Celda o restricción	Qué cambia por la separación
(TEC, Mediciones)	Tiene *crear*, *modificar* y *enviar*; no tiene *aprobar*. Después de enviar pierde *modificar* (C2).
(VER, Mediciones)	Tiene *aprobar* y *devolver* con la condición C3, también después del cierre; no tiene *crear* ni *modificar*.
(SIS, Certificados)	*Emitir* lo tiene solo el sistema, con C4. Ninguna fila de persona lo tiene.
Columna Enmiendas	*Solicitar* (TEC, VER, GER), *corregir* (TEC), *revisar* (VER) y *autorizar* (GER), cada uno con su condición C7 a C10.
Columnas Períodos y Asignaciones	ADM registra el período y GER lo abre o lo cierra (C14). SUP asigna, y no a sí mismo (C19).
Columnas Fincas y Cuentas	ADM *propone*; GER *aprueba* (C11, C12). Nadie toca su propia cuenta.
Toda decisión sobre una finca	No la toma quien declaró un vínculo con su titular (C17). **[minuta P-15]**
Roles mutuamente excluyentes	Todos los pares, estáticos; TEC–VER, dinámica. **[minuta P-01]**
Cardinalidad	Al menos dos VER activos mientras haya mediciones sin dictamen.

5.6 Qué fricción introduce y cómo se maneja

- **Siempre hacen falta dos personas disponibles.** Si el único verificador presente participó en la medición, esa medición espera. Se maneja con la cardinalidad mínima, con una cola que le muestra a cada uno solo lo que sí puede dictaminar y con un aviso a GER cuando una medición lleva varios días sin verificador elegible. **No existe un atajo de emergencia para aprobar lo propio**: sería precisamente el hueco que el auditor buscaría.
- **Las devoluciones cuestan tiempo de campo**, y el cliente confirmó que el verificador devuelve con observaciones y no edita. **[minuta P-03]** Se reduce validando rangos al registrar, para que un error de digitación no llegue al verificador.
- **Una enmienda necesita tres personas, y cuatro si no la solicita el técnico.** Es lenta a propósito. La acotan el plazo de 10 días hábiles para corregir, la clasificación automática y una gerente suplente. Se espera que sean pocas por período. [supuesto P-09]
- **Con solo dos verificadores, una enmienda material puede quedarse sin revisor**: si la solicita uno sobre lo que aprobó el otro. El sistema lo avisa: la presenta entonces el técnico o la Gerencia, y quien encontró el error queda libre para revisarla.
- **La flexibilidad pide un trámite previo:** el supervisor crea la asignación temporal, y ADM y GER la habilitación de un verificador. Así la excepción queda a nombre de alguien y vence sola.
- **La Gerencia concentra las segundas firmas.** Se compensa con que nunca inicia lo que aprueba, no registra ni aprueba mediciones, ya no asigna fincas, no resuelve sus propias alertas, y con que sus decisiones son lo primero que revisa el auditor externo.
- **Lo que la técnica no resuelve: la colusión y el vínculo no declarado.** Si un técnico y un verificador se ponen de acuerdo, el flujo se cumple, y la abstención solo ve los vínculos declarados. La separación sube el costo del fraude de una persona a dos. Quedan la rotación, un indicador que avisa cuando un verificador aprueba una proporción inusual de lo que mide un mismo técnico o de una misma finca, la sanción por omitir un vínculo y la auditoría externa.

Anexo A. Respuestas del cliente y supuestos declarados

La primera versión de este documento se escribió con supuestos de trabajo. El cliente respondió por escrito catorce de las veintiséis consultas del equipo; la minuta completa es el Anexo A del informe de políticas. Estas son las respuestas que tocan este documento y lo que cambió con cada una.

Consulta	Supuesto original	Lo que respondió el cliente	Qué cambió aquí
P-01	Un verificador nunca registra mediciones.	Algunos fueron técnicos y, por excepción, pueden medir. Hace falta revisión independiente sin impedir otras tareas.	Exclusión TEC–VER dinámica y habilitación temporal (3.4). La técnica no cambió.
P-02	Hay al menos dos verificadores.	No hay cifras; el diseño no debe depender de cantidades fijas.	Umbrales por percentil (4); la rotación dejó de darse por viable.
P-03	El verificador siempre devuelve; nunca edita.	Confirmado. Tras la aprobación, procedimiento formal con historial.	En la enmienda corrige el técnico (5.3).
P-05	La Gerencia abre y cierra períodos y asigna fincas.	Decide la coordinación de certificación y registra el personal administrativo. Asignan los supervisores de campo.	Rol SUP; ADM registra y GER aprueba los períodos (3).
P-06	Lo no aprobado al cierre queda fuera.	La revisión puede terminar después del cierre.	C3 vale con el período cerrado (R12).
P-07	Autoriza la Gerencia y verifica un verificador que no participó.	Autorización final con revisión técnica previa; solicitante, revisor y autorizador independientes. El verificador distinto queda a criterio del equipo.	Nuevo orden de la enmienda y la sección 5.3; regla H4.
P-08	El certificado se revoca y se reemite.	Evaluar si sigue válido; nunca dos vigentes ni uno borrado; coordinar si se vendió.	Regla de materialidad y registro de comercialización (5.3).
P-10	Avisar, confirmar y bloquear.	Como mínimo avisar; respuesta según la gravedad; no bloquear de inmediato.	Niveles y señales (4.1); H1 y H3 reescritos.
P-11	El técnico solo ve sus fincas asignadas.	Confirmado, con flexibilidad para apoyos, sustituciones y visitas extraordinarias.	Asignación temporal (4).
P-15	Los dueños entran y pueden autorizar representantes.	Personas físicas y sociedades; no hay registro de vínculos con empleados.	Abstención por vínculo declarado (3.3, 5.6).
P-18	Se citaba ISO/IEC 17029 como norma de los auditores.	No hay una norma definida.	ISO/IEC 17029 queda como referencia (5.2).

Supuestos que el equipo fijó. El cliente no respondió estas consultas y dejó la decisión al equipo. Cada una indica qué se ajusta si el dato real resulta distinto.

Consulta	Supuesto declarado	Qué se ajusta si es otro
P-09	Las enmiendas son pocas por período.	La fricción aceptable de la enmienda (5.6).
P-12	Jornada de lunes a viernes, de 6:00 a 19:00.	Valores de H2 y H3.
P-13	Umbrales iniciales de 40, 60 y 80 fincas por día.	Valores de H1, hasta calibrarlos.
P-14	El personal firma confidencialidad y sabe que se registra.	Proporcionalidad de los controles.
P-19	Las consultas se conservan dos años.	Plazo de los datos de H1 y H3.
P-20	La Gerencia aprueba toda asignación de rol.	Administración de roles (3.4).

Referencias

Abadi, M., & Fournet, C. (2003). Access control based on execution history. En *Proceedings of the 10th Annual Network and Distributed System Security Symposium* (pp. 107–121). Internet Society.

Biba, K. J. (1977). *Integrity considerations for secure computer systems* (Informe técnico MTR-3153). The MITRE Corporation.

Brewer, D. F. C., & Nash, M. J. (1989). The Chinese Wall security policy. En *Proceedings of the 1989 IEEE Symposium on Security and Privacy* (pp. 206–214). IEEE. https://doi.org/10.1109/SECPRI.1989.36295

Clark, D. D., & Wilson, D. R. (1987). A comparison of commercial and military computer security policies. En *Proceedings of the 1987 IEEE Symposium on Security and Privacy* (pp. 184–194). IEEE. https://doi.org/10.1109/SP.1987.10001

Hu, V. C., Ferraiolo, D., Kuhn, R., Schnitzer, A., Sandlin, K., Miller, R., & Scarfone, K. (2014). *Guide to attribute based access control (ABAC) definition and considerations* (NIST SP 800-162). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-162

International Organization for Standardization. (2019). *Conformity assessment: General principles and requirements for validation and verification bodies* (ISO/IEC 17029:2019).

Kuhn, D. R., Coyne, E. J., & Weil, T. R. (2010). Adding attributes to role-based access control. *Computer, 43*(6), 79–81. https://doi.org/10.1109/MC.2010.155

Li, N., Tripunitara, M. V., & Bizri, Z. (2007). On mutually exclusive roles and separation-of-duty. *ACM Transactions on Information and System Security, 10*(2), artículo 5. https://doi.org/10.1145/1237500.1237501

Nash, M. J., & Poland, K. R. (1990). Some conundrums concerning separation of duty. En *Proceedings of the 1990 IEEE Symposium on Security and Privacy* (pp. 201–207). IEEE. https://doi.org/10.1109/RISP.1990.63851

Sandhu, R. S., Coyne, E. J., Feinstein, H. L., & Youman, C. E. (1996). Role-based access control models. *Computer, 29*(2), 38–47. https://doi.org/10.1109/2.485845

Simon, R. T., & Zurko, M. E. (1997). Separation of duty in role-based environments. En *Proceedings of the 10th Computer Security Foundations Workshop* (pp. 183–194). IEEE. https://doi.org/10.1109/CSFW.1997.596811

Vargas Rivera, A. (2026a). *Material de estudio, clase 10: Matriz de control de acceso* [Material de clase]. Curso CE-1115 Seguridad de la Información, Instituto Tecnológico de Costa Rica.

Vargas Rivera, A. (2026b). *Material de estudio, clase 11: Acceso controlado por historial (HBAC)* [Material de clase]. Curso CE-1115 Seguridad de la Información, Instituto Tecnológico de Costa Rica.

Vargas Rivera, A. (2026c). *Proyecto, parte 1: Diseño del control de acceso* [Enunciado de proyecto, incluye la carta de encargo de Verdeazul Carbono S.A.]. Curso CE-1115 Seguridad de la Información, Instituto Tecnológico de Costa Rica.